

7.3A Penetration Testing

Control Type: Advisory	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•	•	•
Control Definition Control Objective: Validate the operational security configuration, identify security gaps by performing regular penetration testing and act upon results. In-scope components: • Jump servers used to access the secure zone • Dedicated operator PCs • Data exchange layer (the entry points to the secure zone or flows established to the secure zone components should be considered) • Access to Swift-related components (including interfaces, GUI, HSM, Swift and customer (client) connectors) • systems or virtual machines hosting Swift-related components • network devices protecting the secure zone or the customer client connectors • Access to remote (operated by a third party) virtualisation or cloud platform hosting Swift-related VMs and the related management PCs Notes: • Tests are performed in line with the Swift Customer Testing Policy. As such, Swift-specific applications, Alliance Connect products, including the VPN boxes and their virtual instances, and Swift-central services such as SwiftNet InterAct, FileAct, FIN, SwiftNet Instant, or WebAccess are not expected to be tested. • The CSP FAQ (Knowledge Base article 5021823 related to control 7.3) provides additional details on the scoping and the testing scenarios to consider. It is not expected that all components, underlying systems and environments are fully tested at each penetration testing exercise. However, all relevant systems must be considered as part of the overall penetration testing programme that ensures global and comprehensive coverage over the exercises. This programme can rely on previous but still recent (not older than 3 years) exercises (including Red Team or Threat Led Penetration Test exercises) covering part of the overall infrastructure subject to the penetration testing exercise (such as network, physical environment, or authentication services). Risk Drivers: • Unknown security vulnerabilities or security misconfigurations						
Implementation Guidance Control Statement: Application, system, and network penetration testing is regularly conducted towards the secure zone, the Swift-related components and the dedicated operator PCs or, when used, the jump servers. Control Context: Penetration testing is based on simulated attacks that use similar technologies to those deployed in real attacks. It is used to determine the pathways that attackers might use, and the depth to which the attackers may be able to access the targeted environment. Conducting these simulations is an effective tool for identifying weaknesses in the environment which may require correction, improvement, or additional controls. Red Team and Threat Led Penetration Test (TLPT) exercises that usually go further, in terms of time, resources, coverage and tactics than (black box) penetration testing on operational components, are valid options to fulfil this control when effectively covering the infrastructure subject to the penetration testing exercise. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's						

implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives).

- The organisation uses a risk-based approach, in line with the institution global penetration testing strategy, to determine the scope (for example, access to the secure zone, or a specific server including potential other services supporting the secure zone), method (for example by sharing or not the internal structure, design or implementation) and attack origin (for example, internal, from within or outside the secure zone, or external attack) for the test.
- Penetration testing is performed at least every 2 years in line also with local regulations, and ideally as well after significant changes to the environment (for example, introduction of new/different servers, new operating systems, underlying technology such as virtualisation or new network device technology, network design change).
- Comprehensive testing of all the in-scope components is expected every 4 years building also on previous, but still recent, interim testing.
- Penetration testing is carefully planned and performed to avoid potential availability or integrity impacts.
- Penetration testing is performed by expert staff independent from the team in charge of the Swift infrastructure (internal Red Team or external resources). The testing methodology and scenarios adapt to evolving threats and changes in the infrastructure.
- Network devices and system penetration testing (for example, rule bases and configurations review) are performed in the service production environment or in a pre-production environment replicating the live environment.
- Sufficient safeguards are in place to minimise any operational impact from conducting the penetration test.
- The outcome of the penetration testing is documented (with restricted access) and used as an input for the security update process or a remediation plan in line with the assessed risks.

Optional Enhancement:

- Penetration testing is performed on Swift-specific applications while adhering to the [Swift Customer Testing Policy](#). This Swift-specific application penetration testing is performed in the testing environment to avoid potential availability or integrity impacts.
- Include in the penetration testing scope the non-Swift related systems present in the Swift secure zone.
- Include in the penetration testing scope the general-purpose operator PCs.
- Perform Red Team or Threat Led Penetration Testing exercises towards the Swift-related components.